

Rapport de scan externe

atlantech.shop

Rapport genere automatiquement a partir du scan externe effectue le 26 juin 2026. Les informations sensibles detectees ne sont pas reproduites en clair.

Synthese rapide

Etat general : correct sur HTTPS, TLS, ports publics et blocage des fichiers critiques majeurs.

Action urgente : bloquer ou supprimer diag.php et deploy.php du serveur de production.

Action SEO : remplacer toutes les URLs localhost par https://atlantech.shop.

Resume executif

Le site public repond correctement en HTTPS et redirige HTTP/www vers le domaine canonique.

Les protections de base sont presentes : HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy et Permissions-Policy.

Les fichiers critiques .env, .git/config, composer.json, config/, includes/, vendor/ et uploads/ ne sont pas lisibles publiquement.

Deux fichiers doivent etre traites en urgence : diag.php et deploy.php sont accessibles publiquement.

Le SEO et le partage social sont affectes par des URLs localhost encore presentes dans la page d'accueil, robots.txt et sitemap.xml.

Findings prioritaires

[CRITIQUE] diag.php public : le fichier repond en 200 et expose des informations d'environnement serveur, version PHP, serveur web, presence/lisibilite du .env, noms de variables sensibles, statut DB et metadonnees de base de donnees. Les valeurs sensibles ne sont pas reproduites ici.

[ELEVE] deploy.php public : le fichier repond en 200 avec un message d'erreur de deploiement. Un script de deploiement ne doit jamais etre expose publiquement, meme s'il echoue actuellement.

[MOYEN] URLs localhost en production : canonical, Open Graph, Twitter image, JSON-LD, robots.txt et sitemap.xml contiennent des references a http://localhost/atlantech-shop/. Cela nuit au SEO, aux apercus sociaux et peut indiquer une configuration de production incomplete.

[MOYEN] Cookies de session : PHPSESSID est marque Secure, mais HttpOnly et SameSite n'ont pas ete observes dans Set-Cookie. Recommandation : activer HttpOnly et SameSite=Lax ou Strict.

[MOYEN] CSP permissive : la Content-Security-Policy contient unsafe-inline et unsafe-eval. C'est acceptable temporairement pour compatibilite, mais cela reduit fortement la protection contre XSS.

[INFO] Portails admin : plusieurs pages de login admin sont publiques. Si cela est voulu, ajouter 2FA, rate limiting, logs d'alerte et eventuellement restriction IP/VPN.

Preuves observees

HTTPS : <https://atlantech.shop/> retourne 200 OK.

HTTP : <http://atlantech.shop/> redirige en 301 vers <https://atlantech.shop/>.

WWW : <https://www.atlantech.shop/> redirige en 301 vers <https://atlantech.shop/>.

TLS : certificat Let's Encrypt pour CN=atlantech.shop, valide du 15 juin 2026 au 13 septembre 2026.

Ports TCP testes : 80 et 443 ouverts. 21, 22, 25, 53, 110, 143, 465, 587, 993, 995, 2083, 2087, 3306, 8080 et 8443 non ouverts dans ce test rapide.

Fichiers/dossiers sensibles bloques : /.env 403, /.git/config 403, /composer.json 403, /composer.lock 403, /config/database.php 403, /config/moncash.php 403, /includes/helpers.php 403, /vendor/ 403, /uploads/ 403.

Artefacts non trouves : /atldb.sql 404, /atldb_clean.sql 404, /atlantech-shop-prod.zip 404, /diag2.php 404, /dbcheck_tmp.php 404, /fixperms.php 404, /unzip_imgs.php 404, /run_migration.php 404, /run-migration-settings.php 404, /admin_config_upload.php 404, /test3.php 404.

Artefacts exposes : /diag.php 200 application/json, /deploy.php 200 text/html.

Pages publiques testees sans erreur PHP visible : /, /shop.php, /cart.php, /account.php, /contact.php, /forgot-password.php, /reset-password.php.

Checkout et retour MonCash : /checkout.php et /moncash-return.php redirigent vers account.php-redirect=checkout lorsqu'aucune session utilisateur n'est presente.

En-tetes HTTP observes

Strict-Transport-Security : max-age=31536000; includeSubDomains; preload

Content-Security-Policy : presente, mais avec unsafe-inline et unsafe-eval.

X-Frame-Options : SAMEORIGIN

X-Content-Type-Options : nosniff

Referrer-Policy : strict-origin-when-cross-origin

Permissions-Policy : geolocation=(), microphone=(), camera=()

Server/CDN visible : hcdn ; platform/panel Hostinger visibles dans les reponses.

Set-Cookie observe : PHPSESSID avec Secure, sans HttpOnly/SameSite observes.

Plan d'action recommande

1. Supprimer diag.php du serveur de production ou le bloquer via .htaccess/serveur. Ne jamais laisser un endpoint de diagnostic public.
2. Supprimer deploy.php du serveur public ou le restreindre strictement a un environnement interne/authentifie.
3. Corriger SITE_URL/APP_URL en production pour remplacer localhost par https://atlantech.shop dans canonical, Open Graph, Twitter, JSON-LD, sitemap.xml et robots.txt.
4. Regenerer sitemap.xml avec les URLs de production et verifier robots.txt : Sitemap doit pointer vers <https://atlantech.shop/sitemap.xml>.
5. Activer HttpOnly et SameSite pour les sessions PHP. Exemple php.ini/.user.ini : session.cookie_secure=1, session.cookie_httponly=1, session.cookie_samesite=Lax.
6. Ajouter une protection supplementaire aux logins admin : limitation de tentatives, 2FA, surveillance des IP et alertes sur echecs repetes.

7. Durcir progressivement la CSP en retirant unsafe-eval puis unsafe-inline avec nonce/hash pour les scripts legitimes.

8. Relancer un scan de validation apres correction pour verifier que diag.php/deploy.php ne repondent plus en 200 et que les URLs localhost ont disparu.

Conclusion

L'exposition globale est plutot correcte sur HTTPS, TLS, ports publics et blocage des fichiers sensibles majeurs.

Le risque principal vient de fichiers utilitaires laisses en production, surtout diag.php. La correction est simple et prioritaire.

Une fois diag.php/deploy.php bloques et les URLs localhost corrigees, le site aura une base de securite publique nettement plus propre.